OpenHarmony A 线 30 份报告抽查与沙箱验证

技术报告 | 2026-10-18

最终结论

扫描候选 0 个 confirmed；样本上下文审计确认 1 个独立漏洞；专用 PoC 1 个。扫描结果中的 severity 全部为 unassessed，本文的高危仅表示验证优先级。

范围	数量	结论
有效报告	378	1,645 条诊断
抽样报告	30	20 有候选 + 10 零候选
扫描候选	345	高优先级 283，普通优先级 62
扫描候选 confirmed	0	没有候选通过完整证据门
相邻审计 confirmed	1	CWE-22/CWE-73 路径穿越
专用 PoC	1	attack/fixed/safe/fixed-safe 各 3/3

证据边界

confirmed 必须同时证明真实入口与权限边界、可达敏感操作、攻击者可控触发条件、具体 CIA 影响以及可审计 provenance。编译崩溃、sanitizer 输出、AST 命中或通用控制 harness 触发均不能单独升级为漏洞。

本报告区分三类结论：扫描候选的 not_reproduced/not_testable；样本上下文审计发现的 confirmed；以及仅用于验证工具链的 positive/fixed/safe 方法控制。

1. 抽样、对账与源码绑定

抽样总体为 openharmony-full-scan-20261017 中同时具备 report.md、result.json、run_meta.json 的 378 份记录。使用固定种子 20261018，按 SHA-256(seed NUL repository NUL snapshot_sha256) 稳定排序，从 100 份有候选报告抽取 20 份，从 278 份零候选报告抽取 10 份。选择指纹为 16e7da3a1fe9fda80ae66dcda856b5e776b649c0d3ce9fd40de9240ddf56a979。

核验项	结果
commit	30/30 匹配
Git tree	30/30 匹配
snapshot SHA-256	30/30 匹配
诊断源码 SHA-256	345/345 匹配
引用行	345/345 存在
候选状态	9 not_reproduced；336 not_testable

2. 扫描候选沙箱复核

高优先级规则包括 shared_ptr race 的 CWE-362/潜在 CWE-416、ipc.parcel.copy-range 的潜在 CWE-125、ipc.auth.* 的 CWE-862/863 和 ipc.capability.export 的 CWE-926/668。其余 relay descriptor-boundary 候选进入明细但保持普通优先级。

已有 shared_ptr、lifetime、auth01 harness 只作为方法或控制参考。通用 TSan 正负控制各 3/3 稳定，只能证明方法可用，不证明抽样组件存在数据竞争。345 条扫描候选均缺少完整真实入口、权限边界、目标构建或 CIA 影响证明，因此没有生成扫描候选 PoC。

3. 相邻确认漏洞

Finding ID：ohscanner-contacts-path-traversal-001；组件：openharmony/applications_standard_contacts_data；主 CWE-22，辅 CWE-73。该发现来自样本 2 openharmony/distributeddatamgr_data_share 权限/模式候选的上下文审计，不是扫描器直接命中。

入口为 ContactsDataAbility，URI 为 datashare://com.ohos.contactsdataability，调用者权限边界为 WRITE_CONTACTS。固定 provenance：Contacts commit 341cc3bf41b48e9a5f278dd088f40a2041d2f1c9、tree 2054824c04bb403eeea128a9262edfb3001efa4f；DataShare commit 560c5cdadf08b4beeb691e93d70ff32cc2dca8bd、tree f731230c116c94d7619f5514c828b33ffac69924。

调用链为 DataShareStub::CmdBatchInsert -> UnmarshalValuesBucketToBuffer -> ContactsDataShareStubImpl::BatchInsert -> ContactsDataAbility::BatchInsert -> HandleContactPortrait -> FileUtils::DeleteFile。路径拼接和 unlink 均绑定到真实源码。

4. 触发条件与影响

攻击值：PortraitFileName=../../../base/files/victim.txt；contactId=1；rawContactId=1。解析路径为 /data/storage/el2/group/com.ohos.contactsdataability/photo/../../../base/files/victim.txt，规范化后落在 /data/storage/el2/base/files/victim.txt。

目标不是合法图片，SavePortraitFileAndBlob 失败，但上层仍执行 unlink(srcFilePath)。拥有 WRITE_CONTACTS 的调用者因此可删除 Contacts 服务进程可访问的任意文件，影响完整性与可用性。

5. Docker PoC 与稳定性

固定镜像 ID：sha256:1f28ead56a68352c2bbbbd4fb45523a237f271dc3be827b073b9274986a2a829；Docker Engine 29.1.3；Debian g++ 12.2.0。运行使用 --network none、--read-only、--cap-drop ALL、--security-opt no-new-privileges、--cpus=1、--memory=512m、--memory-swap=512m、--pids-limit=64 和 nofile=64:64；/tmp 与 /data 为 tmpfs；没有宿主进程回退。

用例	稳定性	行为
attack	3/3	victim 文件被删除
fixed	3/3	越界路径拒绝，victim 保留
safe	3/3	合法 allowed.png 处理成功
fixed-safe	3/3	补丁版本合法路径仍成功

ASan/UBSan 二进制编译成功，但探针在进程退出阶段出现段错误，记录为 asan_ubsan_probe_exit=139。该限制不被写成 sanitizer 成功；功能稳定性以 UBSan 3/3 结果为准。

6. 修复建议

1. PortraitFileName 限制 basename，拒绝 /、\\、.、.. 和空字节。
2. contactId、rawContactId 使用严格数字或格式白名单。
3. 构造路径后使用 realpath/canonical path，并确认目标仍位于 photo 目录内。
4. DeleteFile 前再次执行 canonical path allowlist 校验；文件 helper 使用显式 allowlist。
5. BatchInsert 增加 schema/字段白名单和类型校验。
6. 将 positive、fixed、safe、unrelated 控制纳入持续回归，并保存补丁前后差异。
7. 在完整 OpenHarmony 镜像、目标构建配置和 SELinux 域策略下进行产品集成复测。

7. 扫描器改进建议

1. 建模 IPC 入口、UID/权限和 provider 可见性，避免只看局部 AST。
2. 对权限检查增加 guard dominance，区分检查存在与检查支配敏感操作。
3. 对 shared_ptr/生命周期候选输出所有权、别名、析构时序和原子操作证明义务。
4. 将目标构建配置、线程模型和 sanitizer 结果绑定到候选 provenance。
5. 对同文件、同字段和同 sink 候选聚类，突出真实边界违反。
6. 根据入口、权限、sink 和触发条件生成目标适配 harness，区分方法控制与产品 PoC。
7. 分离风险验证优先级与漏洞定级，禁止 unassessed 直接显示为 confirmed severity。
8. 为路径拼接候选增加 basename、canonical path、allowlist 和删除/写入 sink 专门规则。

8. 局限与剩余证明义务

本轮没有完整 OpenHarmony 产品镜像，未验证完整系统策略、目标构建和 SELinux 域策略。PoC 是从真实源码提取的窄化目标适配器，不是整机产品镜像执行。ASan/UBSan 探针退出码 139；Docker Hub 不可访问，使用本地固定镜像。上游补丁尚未审阅，patched_target_adapter 的重验不等于上游补丁已验收。

9. 交付物

Markdown/PDF 技术报告、四页签 Excel、evidence 证据包和 poc/ohscanner-contacts-path-traversal 专用 PoC 均随本交付提供。统计口径为扫描候选 confirmed 0、相邻 confirmed 1、总 confirmed 1、专用 PoC 1。